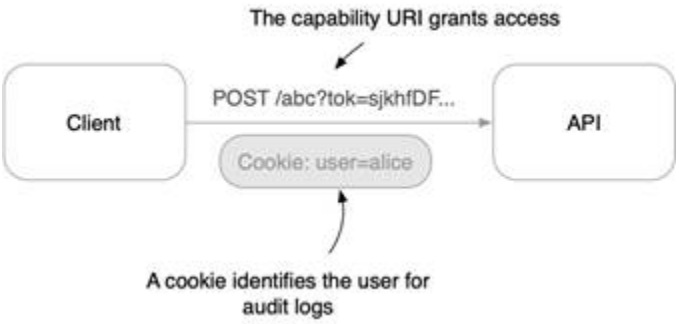


Figure 9.5 By combining capability URIs with a traditional authentication mechanism such as cookies, the API can enforce access using capabilities while authenticating identity claims using the cookie. The same capability URI can be shared between users, but the API is still able to positively identify each of them.

When developing a REST API, the second option is often attractive because you can reuse traditional cookie-based authentication technologies such as a centralized OpenID Connect identity provider (chapter 7). This is the approach taken in the Natter API, where the permissions for an API call come from a capability URI, but some API calls need additional user authentication using a traditional mechanism such as HTTP Basic authentication or an authentication token or cookie. A problem arises, however, when you want to use the same mechanism to communicate both forms of credential, as is the case in Natter now that you've switched to use the Authorization header to communicate the capability token. For example, if you try to post a new message to a social space using Basic authentication the request will end up with two Authorization headers: